

网络安全实践课程

Cyber Practice Lab

南京航空航天大学·信息安全

赵彦超

开始 →

课程信息

上课时间

周次	星期	节次
第 11-16 周	星期一	第 7-10 节
第 11-14 周	星期三	第 9-11 节
第 15-17 周	星期三	第 5-8 节

实验安排

- 共 12 个实验，每周在 QQ 群发布 2 个实验的密码，完成 2 个即可
- 实验在本地 Kali 环境（127.0.0.1）进行
- 在系统里看到作业，每周三提交上一周的两个实验报告

助教团队



于磊



李博文



李晔



杨超越



周健文

有问题可在 QQ 群随时提问，助教会及时答复

重要原则：课程边界

- 1 △ 所有实验严格限制在 127.0.0.1 范围内
- 2
- 3 禁止扫描 campus 网络、同学主机或任何外部 IP
- 4
- 5 违规者将被终止实验资格并报告教务

为什么？

- 这是一个**隔离的本地实验环境**
- 攻击真实系统是**违法行为**（《网络安全法》第27条）
- 你的任务是**掌握防御技术**，不是伤害他人

课程概述

我们要做什么？

- 12 个黑客攻防实验，从零构建攻击者视角
- 真实漏洞靶场，而非模拟环境
- 完整攻击链：侦察 → 利用 → 横向 → 目标达成
- 技术报告写作，锻炼表达与复盘能力

你将掌握

工具	用途
nmap / curl	侦察与指纹识别
Burp Suite	Web 漏洞测试
Wireshark	流量分析与 C2 检测

为什么使用 Kali Linux ?

Kali 是"黑客工具箱"

- ▣ 预装 **600+** 安全工具：nmap、Wireshark、Burp Suite、sqlmap、msfconsole...
- ▣ 开箱即用：无需逐个安装配置，节省大量时间
- ▣ 专为渗透测试设计：系统级权限、定制内核、裸机性能
- ▣ 基于 **Debian**：稳定、可靠、社区活跃

学生本地环境优势

对比项	普通虚拟机	本地 Kali 实验环境
工具安装	需自行配置	课程镜像已集成
网络隔离	难以保证	127.0.0.1 绝对安全
实验记录	难以追溯	本地保存随时复盘

所有攻击限制在 127.0.0.1 ，不侵犯任何真实系统

实验环境架构

实验列表

#	主题	靶场
01-02	侦察·信息泄露	nginx-lab
03-04	认证审计·SQL注入	ssh-lab / Juice Shop
05-06	XSS·文件上传	Juice Shop / upload-lab
07-08	命令注入·权限提升	cmd-lab / priv-lab
09-10	流量分析·IDS告警	traffic-lab / eve.json
11-12	日志关联·事件响应	incident-lab

实验关联：完整攻击链

-
- ```
graph TD; 1[1 侦察 01-02] --> 2[2 ↓]; 2 --> 3[3 初始访问 03-04 认证、SQL注入]; 3 --> 4[4 ↓]; 4 --> 5[5 Web漏洞利用 05-06 XSS、文件上传]; 5 --> 6[6 ↓]; 6 --> 7[7 后渗透 07-08 命令注入、权限提升]; 7 --> 8[8 ↓]; 8 --> 9[9 检测与追踪 09-11 流量分析、日志关联]; 9 --> 10[10 ↓]; 10 --> 11[11 事件响应 12 综合事件响应];
```
- 1 侦察 (01-02)
  - 2 ↓
  - 3 初始访问 (03-04 认证、SQL注入)
  - 4 ↓
  - 5 Web漏洞利用 (05-06 XSS、文件上传)
  - 6 ↓
  - 7 后渗透 (07-08 命令注入、权限提升)
  - 8 ↓
  - 9 检测与追踪 (09-11 流量分析、日志关联)
  - 10 ↓
  - 11 事件响应 (12 综合事件响应)

前 8 个实验 → 站在攻击者角度，从零搭建攻击链

后 4 个实验 → 站在防御者角度，检测、分析、响应攻击

# 快速上手：启动第一个实验

```
1 # 第一步：进入工作目录
2 cd ~/cyber-practice
3
4 # 第二步：安装环境（仅首次）
5 ./install-kali.sh
6
7 # 第三步：检查工具是否就绪
8 ./check-env.sh
9
10 # 第四步：进入学生入口（渐进式引导界面）
11 ./student.sh
```

□ `./student.sh` 会显示 TUI 菜单，输入密码解锁实验，即可逐步开始。

## 实验操作流程

1. 进入学生入口  
./student.sh
2. 获取本周密码 → 解锁实验 → 逐步阅读 WHY / DO / CHECK  
WHY：为什么要这么做（原理）  
DO：执行什么命令（操作）  
CHECK：验证操作是否正确
3. 自动验证或手动确认完成  
每步完成后自动进入下一步
4. 完成实验 → 查看交付物要求  
查阅 tutorial/TUTORIAL.md 中的「交付物」章节  
将报告提交至超星平台

提示：卡住时按 h 获取渐进式提示，最后才会看到完整答案。

# 靶场服务一览

| 服务         | 端口       | 类型         |
|------------|----------|------------|
| nginx-lab  | <8082 /> | Web 信息泄露   |
| ssh-lab    | <2222 /> | 弱密码 SSH    |
| upload-lab | <8086 /> | 文件上传漏洞     |
| cmd-lab    | <8087 /> | 命令注入 RCE   |
| Juice Shop | <3000 /> | SQL 注入、XSS |
| WebGoat    | <8080 /> | OWASP 靶场   |

# 实验报告要求

| 维度     | 分值 |
|--------|----|
| 操作完成度  | 20 |
| 证据收集   | 25 |
| 技术原理阐述 | 20 |
| 防御方案   | 20 |
| 报告质量   | 15 |

常见错误：只有截图、分析不够深入、防御方案笼统、未答思考题

# 工具速查

```
1 # 学生入口 (TUI 菜单, 逐步引导)
2 ./student.sh
3
4 # 启动实验 (如果不用 student.sh)
5 ./reset-lab.sh lab04
6
7 # 端口扫描
8 nmap -sS -p 3000,8080,8082,8086,2222 127.0.0.1
9
10 # HTTP 检测
11 curl -I http://127.0.0.1:8082/
12
13 # Docker 操作
14 docker compose ps
15 docker logs nginx-lab 2>&1 | tail -20
16
17 # 启动/停止实验
18 ./start-lab.sh lab04
19 ./stop-lab.sh
20 ./reset-lab.sh lab04
21
22 # 验证环境
23 ./verify-lab-env.sh
```

# 学习建议

## 思维方式

□ 进攻者 — 你要知道攻击是怎么发生的，才能知道如何防御它。

- 理解攻击原理再动手
- 关注攻击者第一步（侦察？弱口令？）
- 完整链条：侦察 → 初始访问 → 横向 → 目标

□ 防御者 — 做完攻击实验后，问自己怎么发现这种攻击？

- 每个实验要求提出防御方案
- 这是核心输出

# 记录习惯

- 边做边截图，不要事后补
- 命令输出直接复制保存
- 日志分析要标注关键行
- 做完实验后关闭虚拟机，节省资源



# 常见问题

## Q：工具报错 "permission denied"

```
1 # Docker 需要 root 权限
2 sudo docker compose up -d
3
4 # 或者将当前用户加入 docker 组（需要重新登录）
5 sudo usermod -aG docker $USER
6 newgrp docker
```

## Q：服务启动后无法访问

```
1 # 重置实验
2 ./reset-lab.sh lab04
3
4 # 检查容器状态
5 docker compose ps
```

## Q：实验手册的 jq 命令报错

```
1 # eve.json 是 NDJSON 格式，需要加 -s
2 jq -s '.[[] | .alert.signature' evidence/ids/eve.json
```

# 资源链接

## 漏洞数据库

- **CVE** : [cve.mitre.org](https://cve.mitre.org)
- **NVD** : [nvd.nist.gov](https://nvd.nist.gov)
- **Exploit-DB** : [exploit-db.com](https://exploit-db.com)
- **OWASP Top 10** : [owasp.org/www-project-top-ten](https://owasp.org/www-project-top-ten)
- **ATT&CK Matrix** : [attack.mitre.org](https://attack.mitre.org)

## 实验手册

每个实验的 `TUTORIAL.md` 在对应目录下（需输入密码解锁）：

```
1 labs/lab01-recon/tutorial/TUTORIAL.md
2 labs/lab02-info-leak/tutorial/TUTORIAL.md
3 ...
```

# 下一步

## 现在开始

```
1 cd ~/cyber-practice
2 ./student.sh
```

## 阅读

- 解锁 `lab01-recon` 后阅读 `tutorial/TUTORIAL.md`
- 查看 `docs/diagrams/` （架构图、攻击链图）

有问题随时在 QQ 群提问 □